

SGSI - ISO 27001

Mejora Continua

Gestión de Incidentes y Plan de Acción Preventivo

Departamento EDI/4 - Robert Bosch Sistemas Automotrices

Responsables

Ávalos Rangel Hazel Mario – 181801
Cabrera Meza Jorge Alejandro - 183095
González Delgado Ángel Josué - 182837
López Castro Diego – 182032
López Monsiváis Jorge Emmanuel – 179842

CONFIDENTIAL

Análisis de Incidente Crítico

Evaluación forense y lecciones aprendidas tras el compromiso físico
de un activo corporativo.

CONFIDENTIAL



DESCRIPCIÓN DEL INCIDENTE

¿Qué sucedió?

Un colaborador del equipo EDI/4 sufrió el robo de su laptop corporativa mientras trabajaba de forma remota en una cafetería pública.

⚠ Negligencia: El equipo se dejó desbloqueado y sin supervisión.

🕒 Exposición: Sesión activa durante el robo, facilitando acceso potencial a datos.

🕒 Riesgo: Ventana crítica antes del bloqueo automático.



CONFIDENTIAL

ANÁLISIS DE CAUSA RAÍZ

Factor Humano

Incumplimiento de las políticas de custodia física. La formación se centraba en riesgos digitales, omitiendo la seguridad física presencial.

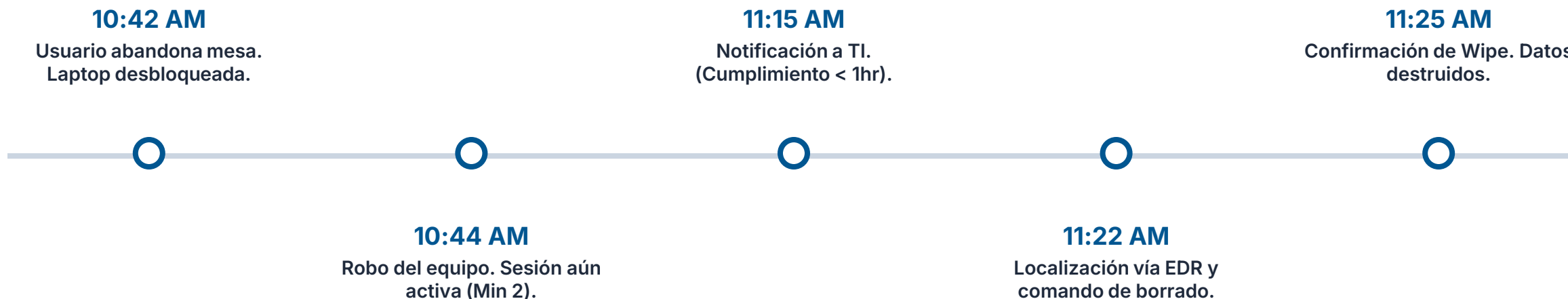
Brecha Técnica

La configuración de bloqueo (5 min) era demasiado amplia para entornos públicos, permitiendo que el ladrón tuviera acceso inmediato al SO.

Respuesta Eficaz

El protocolo reactivo (EDR/Borrado Remoto) funcionó, mitigando el impacto final a pesar del error inicial del usuario.

CRONOLOGÍA DEL INCIDENTE



CONFIDENTIAL

EFFECTIVIDAD DEL PROTOCOLO

33m

Tiempo de Reporte

10m

Respuesta de TI

100%

Integridad Salvada

"La contención rápida evitó que el incidente escalara a una brecha de datos masiva."

CONFIDENTIAL



Plan de Acción y Mejora

Transformando vulnerabilidades en fortalezas
institucionales.

ESTRATEGIA PREVENTIVA



Baseline 3.0

Reducción del bloqueo de pantalla automático de 5 a 3 minutos para todo el personal EDI.



Formación Física

Nuevo módulo obligatorio: "Custodia de Activos en Espacios Públicos" (Ingeniería Social Presencial).



Cultura Win+L

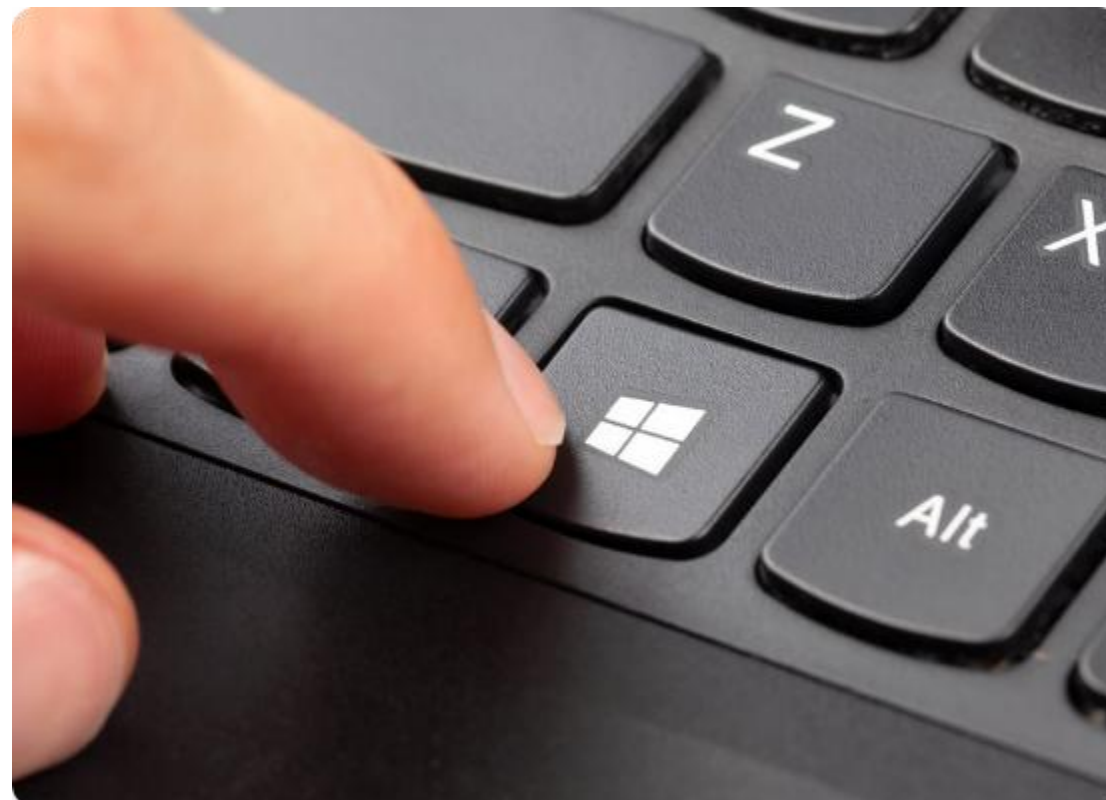
Campaña de concientización para el bloqueo manual instantáneo al levantarse.

HÁBITO DE SEGURIDAD

Win + L: El atajo que salva datos

Un segundo de acción previene meses de investigación. Nuestra nueva directriz enfatiza:

- Bloqueo manual mandatorio al alejarse a más de 1 metro del equipo.
- Uso de candados Kensington en lugares fijos.
- Notificación inmediata ante comportamiento sospechoso en el entorno.



CONFIDENTIAL

TUS 5 SEGUNDOS VALEN ORO

En espacios públicos, la seguridad de tu equipo es TU responsabilidad.



1. BLOQUEA

Win + L antes de levantarte.



2. VIGILA

Nunca dejes tu equipo solo.



3. REPORTA

Llama a TI en < 60 min si algo pasa.

DEPARTAMENTO EDI/4 - SEGURIDAD SIEMPRE

CONCLUSIÓN

"Los controles técnicos nos salvaron esta vez, pero la prevención humana es lo que garantiza la resiliencia a largo plazo."

- ✓ EDR y Cifrado confirmados como efectivos.
- ✓ Protocolo de reporte rápido validado.
- 🔄 El SGSI se ajusta para cerrar la brecha física.

Dudas o Preguntas

La mejora continua es un esfuerzo de todos.

www.bosch.com.mx | EDI/4 Robert Bosch Sistemas Automotrices

CONFIDENTIAL



LECCIÓN APRENDIDA

UN SEGUNDO ES SUFICIENTE

EL INCIDENTE

Un equipo de cómputo portátil perteneciente a EDI/4 fue sustraído en una cafetería pública. El delincuente solo necesitó una ausencia de 2 minutos del colaborador.

LA CAUSA RAÍZ

El estándar de cifrado robusto AES-256 queda completamente neutralizado si el equipo es extraído mientras la sesión de Windows permanece activa y desbloqueada.

¡NO CONFÍES EN EL BLOQUEO AUTOMÁTICO!

Robert Bosch

PROCEDIMIENTO DE CUSTODIA DE ACTIVOS CRÍTICOS

HÁBITO DE SUPERVIVENCIA DIGITAL MANDATORIO

Win

+

L

Bloqueo manual instantáneo antes de alejarte a más de un metro de tu estación de trabajo.

1. BLOQUEA

Presiona de forma mecánica el comando Win+L al levantarte. Asegúrate de ver la pantalla de bloqueo activa antes de retirar la mirada de tu laptop corporativa.

2. VIGILA

En entornos de trabajo remoto (cafeterías, hoteles, aeropuertos), tú eres el único custodio de la propiedad intelectual de Bosch. Nunca dejes activos desatendidos.

3. REPORTA

Ante cualquier pérdida o incidente, notifica de inmediato a la mesa de ayuda de TI dentro de la primera hora. La rapidez es crítica para activar el borrado remoto militar.



MESA DE AYUDA DE TI: EXT. 1900

SEGURIDAD DE LA INFORMACIÓN EDI/4
ISO/IEC 27001 • San Luis Potosí, México • Mayo 2026